Post-quantum transition for device bounded anonymous credentials: a EUDI wallet application

Leonardo Rufini

July 2026

Abstract

In 2026, member states of the European Union are expected to have running their own EUDI wallet applications instances compliant with the ARF architecture guidelines. The goal of the ARF architecture is to provide privacy-preserving anonymous credentials to the users, but the current implementation fails. In the meantime, in 2024 the European Union has published a roadmap for the post quantum digital transition of members digital infrastructures.

No current implementation of anonymous credentials is post quantum secure at the moment, with cryptologist and mathematician in top pubblications claiming that is not possible to build a post quantum anonymous credential scheme with the actual technologies, given hardware constraints and advanced requirements. So we asked ourselves: is it possible to build a post quantum device bounded anonymous credential scheme with the actual technologies, giving hardware constraints and technical difficulties? The answare is **yes**, it is possible.

Moreover, in this thesis we present a post quantum anonymous credentials model that can be deployed with the actual technologies and legacy infrastructures, with NIST standardized post quantum signature schemes. We went furhter and implemented the full model and run it into android devices in order to benchmark the performance and the results are surprising. We also present some optimizations that could be implemented in order to further improve the performance of the scheme, and we show how to implement them with the actual technologies.

Contents

1 Introduction

Anonymous credentials are a powerful tool for preserving privacy in digital interactions between users and service providers. Anonymous credentials were introduced by David Chaum in 1982 [6], and later formalized by Camenisch and Lysyanskaya in 2001 [3, 4]. They allow users to prove their identity or attributes without revealing any additional information about themselves.

The usual model of anonymous credentials consists of three parties:

- The issuer, a central entity who is responsible for issuing credentials to users and eventually revoking them;
- The user, who asks credentials to the issuer and holds them, and eventually use them to prove their identity or attributes to verifiers.
- The verifier, who is responsible for verifying the user's credentials without learning any additional information about the user.

A basic scheme of how this entity interacts with each other is represented in figure 1.

In the first approach [10], the issuer was signing user's credentials using a secure protocol that protects user's attributes. Credential(s) are then showed

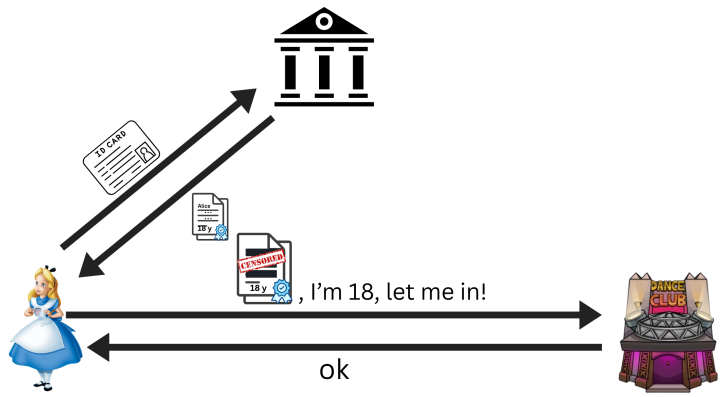

Figure 1: Basic scheme of anonymous credentials.

to a verifier via zero-knowledge proof of knowledge of a credential(s) whose attributes satisfy some predicate.

Systems based on anonymous credentials have been studied and adopted over the years by big tech companies like Micrsoft [11], IBM [5], and are in continuous study and development by the scientific community, facing challenges like performance improvements, revocation lists, legacy infrastructures and hardware constraints, and more recently, post quantum security.

1.1 Post quantum transition

The european union on 11 April 2024 has published a roadmap for the post quantum digital transition of members digital infrastructures [9].

The roadmap is a comprehensive plan that outlines the steps that the European Union will take to transition to post-quantum cryptography. The roadmap includes a timeline for the transition, as well as a list of actions that will be taken to ensure a smooth transition.

The timeline is organized into three major phases:

1. **By the end of 2026**: Initial national PQC transition roadmaps have been established by all Member States, PQC transition planning and pilots for high- and medium-risk use cases have been initiated;

2. **By the end of 2030**: The PQC transition for high-risk use cases has been completed, PQC transition planning and pilots for medium-risk use cases have been completed. Quantum-safe software and firmware upgrades are enabled by default.

3. **By the end of 2035**: The PQC transition for medium-risk use cases has been completed. The PQC transition for low-risk use cases has been completed as much as feasible.

As previously said, this roadmap has been published by the European Commission in 2024. The recent advances in the field of post-quantum computing due to hardware improvements, artificial intelligence accelleration and advances in research have made the Q-day closer then expected, and the transition to post-quantum cryptography more urgent.

On 30 March 2026, Google published a drastical advance in post-quantum cryptography: they reduced consistently the amount of time, resources and qbits needed to break elliptic curves based crytography [2]. In the meanwhile, between April and March 2026, big tech companies like Google [1] and Cloudflare [12] have announced that they will accelerate the transition to post-quantum cryptography, lowering the timeline for the full transition to 2029, instead of 2035.

1.2 Overview

In this thesis, we present a post-quantum anonymous credentials model that can be deployed with the actual technologies and legacy protocols. We require the issuer to adopt ML-DSA NIST standardized post quantum signature scheme, and to sligthly leverage the credentials structure in order to accomodate the larger size of post quantum signatures and public keys, as well as modification to the mdoc structure in order to involve a commitment of the device public key instead of the device public key itself.

In the following sections, we are going to present an overview of the EUDI wallet 2, we perform a full ananlysis of the actual state of the art on device bounded anonymous credentials 3, then we explain how our solution faces and solves the challenges, performing an important advance on the actual state of the art 4. We show how we implemented our solution, giving a reference to our github repository 5, and we present our results 6, future works that we plan to do 7 and conclusion 8.

2 EUropean Digital Identity Wallet

In 2021, the European Commission proposed to adopt a framework for a European Digital Identity [7]. In 2024, the European Commission decided to establish an Architecture Reference Framework (ARF) [8], which consisted of a set of guidelines and properties that each instance of the wallet application should satisfy. This general framework is needed since the commission left freedom to eaech memeber state to implement their own instance of the application, due to different possible credentials structures (for example, french and german national identity cards have different structures and/or attributes) and infrastructures (for example, some member states have already a national identity card with an embedded chip, while others don't).

2.1 Architecture overview

2.1.1 Functionalities

2.1.2 Roles

2.2 Vulnerabilities

3 State of the art/Literture overview on device bounded anonymous credentials

3.1 Anonymous Credentials

3.2 Post quantum anonymous credentials

4 Our solution

4.1 Claim

4.2 Analysis

4.2.1 Security analysis

MAC witness sharing STARK zk proof over the issuer signature needs dilithium verification algorithm. The algorithm takes in input the signature sig, the message being signed e_1 and the public key of the issuer PK_{II}. The message signed by the issuer $e_1$is the sha256 of the credential document. Knowledge of sha256 preimage is hard to prove in STARK winterfell circuit, so we propose the following solution: the Ligero circuit, which has an optimized sha prover, will prove $e_1 = sha256(cred)$, then e_1 is encoded in a binding and hiding commitment realized with information theoretic MAC. ecc ecc ecc. Mathematical proof of MAC security:

$$m = MAC_k(e_1) = MAC_{k_p,k_v}(e_1) = MAC_{a,b}(e_1)$$

We obtain the key as:

$$(a, b) = k_p \oplus k_v$$

where k_p is a secret random 32 bytes key choosen by the prover and k_v is a public verifiable key chosen by the verifier. What security concerns do we have?

1. The prover can try to forge a valid MAC for a different e'_1, but e'_1 would still need to be a valid sha256 of signed credential since the signature is verified by the circuit;

2. The prover could generate k_p after seeing k_v, leading to arbitrary proves;

3. Different presentations could be linkable to the same MAC.

2 is avoidable if we require the prover to generate k_p before seeing k_v, committing to and building k_v with fiat shamir transform on k_p commitment, and 3 is avoidable if we require the prover to generate a different k_p for each presentation.

For 1, we have the following security proof in which we show that is not possible to forge a valid MAC for a different e'_1 without breaking the security of the MAC scheme:

$$m = MAC_k(e_1) = a * e_1 + b = a * e'_1 + b \Rightarrow a * (e_1 - e'_1) = 0$$

which is true either if a $= 0$ or if $e_1 = e'_1$. It has been proven that the probability that $a = 0$ is negligible. if $e_1 = e'_1$ then the prover is proving the same credential, so no forgery is happening. We also now that is not possible to have $m_1 = a' * e_1 + b' = m_2 = a'' * e'_1 + b''$ since the prover is not able to choose a and b due to the verifier participation in the key generation with k_v.

4.2.2 Compliance with eIDAS 2.0 and LoA High

In this section we are going to analyze our solution, taking into account the requirements of the European Commission for the EUDI wallet application, considering both the eIDAS 2.0 regulation and the LoA High (Level of Assurance High).

Dynamic Authentication and Replay Protection
CIR 2015/1502 requires that for LoA High, authentication must be dynamic, creating a proof that changes with each session. The plan fulfills this by including a session transcript (tr) in the Device Binding proof. The device's Secure Element signs this transcript, and the ZK circuit verifies this signature (p256.verify), ensuring the proof cannot be replayed by an attacker who has intercepted a previous proof.

Hardware Binding
The plan enforces Device Binding by extracting the public key (pk_d) from the signed MSO and requiring a proof of possession of the corresponding private key. This ensures the credential is bound to a tamper-resistant WSCD (Wallet Secure Cryptographic Device).

Algorithmic Soundness
The extraction error of the combined STARK/Ligero system is negligible ($O(\eta + d \cdot \log(w) / \mid F \mid)$), providing a robust mathematical barrier against forgery.

Compliance with EUDI ARF Requirements
The implementation satisfies several High-Level Requirements (HLRs) from the EUDI Architecture and Reference Framework:

- **User Sole Control**: The ZKP generation happens entirely on the user's device (orchestrated by the Wallet Unit), ensuring the user has sole control over attribute disclosure;

- **Validity Verification**: The circuit enforces validity checks (tstart¡tnow¡tend) without revealing the actual issuance or expiration dates, as required for privacy-preserving interactions;

5 Implementation

6 Results

7 Future work

8 Conclusion

References

[1] Heather Adkins and Sophie Schmieg. Quantum frontiers may be closer than they appear. Google Blog, 2026. Accessed: May 24, 2026.

[2] Ryan Babbush, Adam Zalcman, Craig Gidney, Michael Broughton, Tanuj Khattar, Hartmut Neven, Thiago Bergamaschi, Justin Drake, and Dan Boneh. Securing elliptic curve cryptocurrencies against quantum vulnerabilities: Resource estimates and mitigations. Cryptology ePrint Archive, Paper 2026/625, 2026.

[3] Jan Camenisch and Anna Lysyanskaya. An efficient system for non-transferable anonymous credentials with optional anonymity revocation. Cryptology ePrint Archive, Paper 2001/019, 2001.

[4] Jan Camenisch and Anna Lysyanskaya. Signature schemes and anonymous credentials from bilinear maps. In Matt Franklin, editor, *Advances in Cryptology – CRYPTO 2004*, pages 56–72, Berlin, Heidelberg, 2004. Springer Berlin Heidelberg.

[5] Jan Camenisch and Els Van Herreweghen. Design and implementation of the idemix anonymous credential system. In *Proceedings of the 9th ACM Conference on Computer and Communications Security*, CCS '02, page 21–30, New York, NY, USA, 2002. Association for Computing Machinery.

[6] David Chaum. Blind signatures for untraceable payments. In David Chaum, Ronald L. Rivest, and Alan T. Sherman, editors, *Advances in Cryptology*, pages 199–203, Boston, MA, 1983. Springer US.

[7] European Commission. Proposal for a Regulation of the European Parliament and of the Council amending Regulation (EU) No 910/2014 as regards establishing a framework for a European Digital Identity. COM(2021) 281 final, 2021. Accessed: May 22, 2026.

[8] European Commission. European Digital Identity Wallet Architecture and Reference Framework — Version 1.4.0, 2024. Accessed: May 22, 2026.

[9] European Commission. Recommendation on a Coordinated Implementation Roadmap for the transition to Post-Quantum Cryptography. Commission Recommendation (EU) 2024/1101, 2024. Accessed: May 24, 2026.

[10] Anna Lysyanskaya. *Signature schemes and applications to cryptographic protocol design*. PhD thesis, Massachusetts Institute of Technology, 2002.

[11] Christian Paquin and Greg Zaverucha. U-prove cryptographic specification v1.1 (revision 3), December 2013. Released under the Open Specification Promise (http://www.microsoft.com/openspecifications/en/us/programs/osp/default.aspx).

[12] Bas Westerbaan. Cloudflare targets 2029 for full post-quantum security. The Cloudflare Blog, 2026. Accessed: May 24, 2026.